

INC-2026-0421 - SFTP Credential Exposure and Emergency Rotation

Security Incident Report | Engineering

Document ID	INC-2026-0421	Seller ID	S002
Department	Engineering	Classification	RESTRICTED
Owner	Admin	Created Date	2026-04-25
Related Scenario ID	SC-008	Document Type	Security Incident Report

RESTRICTED. This report records a credential exposure, the platform response and the controls introduced. It is readable only at RESTRICTED clearance. Do not reproduce, forward or quote its contents in CONFIDENTIAL or INTERNAL material.

1. Incident Summary

Field	Value
Incident ID	INC-2026-0421
Severity	SEV-1 (security)
Classification	RESTRICTED
Service	SFTP gateway, Seller API credential store
Detected	2026-04-21 07:12 IST
Contained	2026-04-21 09:00 IST
Resolved	2026-04-24 16:00 IST
Incident owner	Admin, Platform Administrator (IT)
Engineering support	Vikram Singh
Seller coordination	Rahul Sharma
Seller affected	S002 - BluePeak Electronics
Related ticket	TKT-2026-0421-162 (RESTRICTED)

A valid SFTP credential for the S002 integration was found embedded in a troubleshooting script that had been shared outside the company. Elevated failed authentication attempts were observed against the S002 SFTP endpoint in the same period. No successful unauthorised authentication was confirmed, but the credential was treated as compromised and rotated within 80 minutes of the decision.

2. Impact

Dimension	Detail
Credentials compromised	1 SFTP service credential scoped to the S002 endpoint
Confirmed unauthorised access	None
Failed authentication attempts observed	1,847 over 31 hours, against a baseline under 20 per day

Dimension	Detail
Source addresses	14 distinct, none on the seller's known ranges
Data exfiltration evidence	None found
Seller feed downtime during rotation	80 minutes
Sellers affected	1 (S002)

The credential carried read and write access to the S002 SFTP directory, which holds inbound catalogue, price and stock files. A successful authentication would have permitted an attacker to read the seller's commercial data and, more seriously, to write a modified catalogue or price file that the platform would have ingested as authentic.

That second possibility drove the severity classification. The realistic worst case was not data theft but price manipulation across 142,000 listings.

3. Detection

Detected internally by two independent signals on the same morning.

The first was an authentication anomaly alert: failed authentication attempts against the S002 SFTP endpoint exceeded the configured threshold at 07:12 IST. The endpoint normally sees fewer than 20 failures a day, almost all transient client errors.

The second was a manual finding. While investigating the anomaly, IT searched for the affected account name across internal and public sources and located it in a troubleshooting script fragment that had been shared in an external technical discussion by a member of the support function some weeks earlier. The fragment included the hostname, username and password.

The two signals together converted an ambiguous anomaly into a confirmed exposure within about an hour.

4. Timeline

Time (IST)	Event
21 Apr 07:12	Authentication anomaly alert raised on S002 SFTP endpoint
21 Apr 07:25	IT begins investigation; anomaly confirmed as credential-guessing pattern
21 Apr 07:40	Credential located in an externally shared script fragment
21 Apr 07:40	Ticket TKT-2026-0421-162 opened for seller coordination
21 Apr 08:15	Admin authorises immediate rotation without waiting for seller readiness
21 Apr 08:30	Support briefs the seller by phone; rotation window agreed
21 Apr 09:00	Credential rotated; S002 feeds begin failing as expected
21 Apr 09:20	Access log review for the preceding 90 days begins
21 Apr 10:20	Seller applies new credential; feeds resume
21 Apr 11:00	First catalogue file processed successfully with new credential
21 Apr 14:30	Log review completes: no successful unauthorised authentication
22 Apr 15:00	Joint call with seller on controls and process
22 Apr 17:00	Secret scanning added to CI pipeline, initial sweep started
24 Apr 11:00	IP allowlisting enabled on the S002 SFTP endpoint

Time (IST)	Event
24 Apr 16:00	Incident closed

5. Symptoms

- Failed authentication attempts against one SFTP endpoint rising from under 20 per day to 1,847 over 31 hours.
- Attempts distributed across 14 source addresses, none matching the seller's registered ranges.
- Attempt pattern consistent with automated credential validation rather than brute force: low rate per source, correct username, occasional correct password attempts followed by immediate disconnection.
- No corresponding change in successful authentication volume.
- No anomalous file writes or reads in the SFTP directory.

The pattern of correct-username attempts was what distinguished this from routine internet background noise. An attacker guessing blindly does not produce a correct service account name on a non-obvious endpoint.

6. Affected Systems

System	Role	State
SFTP gateway	Seller file transfer ingress	Exposed credential; no confirmed compromise
Credential store	Held the service credential	Functioning; credential was valid and unrotated
Catalogue importer	Consumed files from the S002 directory	Unaffected; no anomalous files ingested
CI pipeline	Built and deployed support tooling	No secret scanning at the time
Authentication monitoring	Raised the initial alert	Functioning; alert fired correctly

7. Investigation

7.1 How The Credential Escaped

The credential originated in a diagnostic script written by a support engineer to troubleshoot a feed delivery problem on this account. At that time Support had no central diagnostic tooling for seller feeds, so engineers assembled ad hoc scripts, and those scripts contained connection details because there was no credential-resolution mechanism available to them.

The script was later shared externally as part of a technical discussion about SFTP transfer behaviour. The person sharing it believed the credential was a staging credential and therefore harmless.

It was labelled staging. It was not: the S002 integration used the same credential for its staging and production directories, a configuration dating from the 2022 onboarding that had never been reviewed.

7.2 Whether Access Occurred

Access logs for the SFTP endpoint were reviewed for 90 days. The review covered successful authentications, session durations, files read, files written and source addresses.

Check	Finding
Successful authentications from unknown addresses	None
Sessions outside the seller's normal transfer windows	None
Files read beyond the expected inbound set	None
Files written other than by the seller's known process	None
File checksums against seller-supplied manifests	All matched

The conclusion was that the credential was validated by an attacker but not used, or that use was attempted and failed for another reason. The absence of evidence of access was recorded as exactly that, not as evidence of absence.

7.3 Why Rotation Was Not Automatic

Credential rotation for seller service accounts was a manual process requiring a scheduled coordination window with the seller. In practice this meant rotation happened rarely. The exposed credential had been in use unchanged since June 2022, approximately 46 months.

8. Root Cause

A valid production SFTP credential for seller S002 was embedded in a support diagnostic script and shared outside the company. The exposure was possible because Support had no central diagnostic tooling that resolved credentials at runtime, because the account used a single credential for both staging and production directories, because credential rotation was manual and had not occurred in 46 months, and because no secret scanning existed in the CI pipeline to detect credentials in code.

9. Contributing Factors

1. **No secret scanning** in the CI pipeline or in code review.
2. **Shared staging and production credential** on this account, so a credential believed to be low-risk was in fact production-scoped.
3. **Manual rotation** with a coordination burden that discouraged it.
4. **No IP allowlisting** on the endpoint, so a valid credential from any source address would have authenticated.
5. **No central support tooling**, forcing engineers to handle raw credentials.
6. **No periodic access review** of long-lived service credentials.

10. Containment

The containment decision was to rotate immediately rather than to schedule a coordinated rotation with the seller. This deliberately broke the seller's feeds for 80 minutes.

The reasoning was proportionality. An 80-minute feed interruption is recoverable: files queue and are processed on resumption, and no orders or customer transactions depend on the feed within that window. A compromised credential with write access to a catalogue and price feed is not recoverable in the same sense, because ingested price data affects live listings immediately.

The seller accepted this without objection once the reasoning was explained.

11. Resolution

Action	Completed
Credential rotated	2026-04-21 09:00
Separate credentials issued for staging and production directories	2026-04-21 09:00
90-day access log review completed	2026-04-21 14:30
Secret scanning enabled in CI, full repository sweep	2026-05-08
IP allowlisting on the S002 SFTP endpoint	2026-04-24 11:00
Automated 90-day rotation for seller service credentials	2026-06-12
Central support diagnostic tooling with runtime credential resolution	2026-06-30

The repository sweep on 8 May found three further credentials in code, all in internal tooling and none seller-scoped. All three were rotated and removed.

12. Validation

Check	Method	Result
Old credential no longer valid	Authentication attempt with the exposed credential	Rejected
Allowlist effective	Authentication from an off-list address with valid credential	Rejected
Staging and production separated	Configuration review and test authentication	Confirmed separate
Secret scanning effective	Test commit containing a synthetic credential	Build failed as intended
Automated rotation working	Two rotation cycles observed	Both completed without seller impact
Anomaly alerting still effective	Threshold reviewed after allowlisting	Retained; allowlist rejections now also alert

13. Preventive Actions

ID	Action	Owner	Target	Status
PA-1	Secret scanning in CI with build failure on detection	Vikram Singh	2026-05-08	Complete

ID	Action	Owner	Target	Status
PA-2	Automated 90-day rotation for all seller service credentials	Admin	2026-06-12	Complete
PA-3	IP allowlisting on all seller SFTP endpoints	Admin	2026-07-10	Complete
PA-4	Central support diagnostic tooling, no raw credential handling	Vikram Singh	2026-06-30	Complete
PA-5	Separate staging and production credentials for every account	Admin	2026-06-12	Complete
PA-6	Quarterly access review of long-lived service credentials	Admin	2026-07-01	Complete
PA-7	Prohibition on sharing any script containing connection detail	Admin	2026-04-22	Complete

13.1 On PA-7

The policy reminder issued on 22 April makes no distinction between staging and production credentials. That distinction was the reasoning that led to this exposure, and it is not a distinction an attacker respects. The rule is now absolute: no script containing any connection detail leaves the company, regardless of environment.

14. Follow-Up

The Security Incident Response Policy was reviewed against this incident. The response followed the policy correctly, including the authority of the Platform Administrator to authorise immediate containment without seller consent. No policy change was required.

The Data Access Policy was amended in June 2026 to require automated rotation for all machine credentials and to prohibit shared credentials across environments.

Post-incident review held 25 April 2026 with IT, Engineering and Support. The review's conclusion was that the support engineer's behaviour was a predictable consequence of not providing adequate tooling, and that the corrective action belonged with the tooling rather than with the individual.